

Codexity: Secure AI-assisted Code Generation

Sung Yong Kim
National University of Singapore
Singapore
sungyongkimmoi@gmail.com

Yannic Noller
Singapore University of Technology and Design
Singapore
yannic.noller@acm.org

Zhiyu Fan
National University of Singapore
Singapore
zhiyufan@comp.nus.edu.sg

Abhik Roychoudhury
National University of Singapore
Singapore
abhik@comp.nus.edu.sg

ABSTRACT

Despite the impressive performance of Large Language Models (LLMs) in software development activities, recent studies show the concern of introducing vulnerabilities into software codebase by AI programming assistants (e.g., Copilot, CodeWhisperer). In this work, we present CODEXITY, a security-focused code generation framework integrated with five LLMs. CODEXITY leverages the feedback of static analysis tools such as Infer and CppCheck to mitigate security vulnerabilities in LLM-generated programs. Our evaluation in a real-world benchmark with 751 automatically generated vulnerable subjects demonstrates CODEXITY can prevent 60% of the vulnerabilities being exposed to the software developer.

- Video: <https://youtu.be/om6CYGfbNnM>
- Tool and Data: <https://github.com/Codexity-APR/Codexity>,
<https://doi.org/10.5281/zenodo.10572275>

KEYWORDS

security, code generation, large language model

1 INTRODUCTION

The recent advance of fundamental Large Language Models (LLMs) for code has shown surprising results in many software engineering applications like code completion, code summarization, etc. Consequently, AI programming assistants like Copilot and CodeWhisperer have reshaped the way of software development. Despite their advantages and conveniences, researchers have expressed concerns that LLMs can introduce security vulnerabilities into the auto-generated code that developers could overlook [10, 15, 22]. Without a secure integration mechanism for these LLM-generated codes, they could thus compromise the entire software system. Automated Program Repair (APR) [16] is a technique that aims to fix bugs automatically, with many successful applications in fixing security vulnerabilities [11, 14, 19, 24, 26]. However, existing APR approaches primarily focus on fixing human-written programs and typically assume timeouts of ≥ 1 hour [20]. Such assumptions might fit in CI workflows or nightly build scenarios but do not satisfy the tight requirements for an *in-time* vulnerability prevention needed for the automated code generation/completion inside the IDE.

To tackle these challenges, we present CODEXITY, the first security-focused code generation framework. CODEXITY integrates LLMs with static analyzers [6, 18] to establish security awareness and act as the first guard to prevent potential vulnerabilities introduced by AI programming assistants. In our experiments with 990 real-world

code completion attempts, we demonstrate that, compared to ChatGPT, CODEXITY prevents the generation of 60% of the vulnerabilities. Our core contributions are as follows:

- CODEXITY, a security-focused code generation framework providing timely vulnerability-free LLM-generated programs for developers. Additionally, CODEXITY employs a flexible architecture that allows user-customized LLM deployment.
- Real-world benchmark for LLM-generated programs, consisting of 751 vulnerable subjects from 90 publicly available prompts.

2 MOTIVATING EXAMPLE

Listing 1 displays a program generated by an LLM. It is meant to answer a StackOverflow inquiry¹ about storing user-input strings in variables. Our assembly of Static Application Security Testing (SAST) tools identified a potential vulnerability (highlighted in red in) that is related to CWE-119:

"CWE-119 identified at lines 7 and 9. The triggered concern: *scanf() without field width limits can crash with huge input data.*"

To prevent such vulnerabilities from being exposed to the software developer, we provide this additional feedback to the LLM in the form of a structured prompt, emulating a dialogue with the goal of crafting code devoid of these flaws (see Figure 1). Consequently, the LLM responded by producing the revised code, eliminating the buffer overflow issues, as evidenced in Listing 2. As highlighted in green, the code is no longer vulnerable because the format specifier %49s is used in both scanf calls, meaning that scanf will add at most 49 characters into the arrays. By specifying the maximum number of characters, the code prevents buffer overflow vulnerabilities if the input data exceeds the allocated buffer size.

3 DESIGN AND METHODOLOGY

This section introduces the workflow of CODEXITY and two vulnerability-preventing repair strategies.

3.1 CODEXITY Workflow

In CODEXITY's workflow, the user first needs to select a repair strategy in the configuration setting to activate the system. CODEXITY currently offers the two strategies *Iteration Repair* and *Preshot Repair* catering for different requirements in the computation power. Then, the user can invoke CODEXITY to complete their code while

¹<https://stackoverflow.com/questions/19063213/string-ask-and-store>

```

1 #include <stdio.h>
2 #include <errno.h>
3 #include <string.h>
4 int main(void){
5     char reference[50], query[50];
6     printf("\n Enter reference genome file name: ");
7     scanf("%s", reference);
8     printf("\n Enter query genome file name: ");
9     scanf("%s", query);
10    return 0;
11 }

```

Listing 1: Vulnerable code generated by LLM

```

1 #include <stdio.h>
2 #include <errno.h>
3 #include <string.h>
4 int main(void){
5     char reference[50], query[50];
6     printf("\n Enter reference genome file name: ");
7     scanf("%49s", reference);
8     printf("\n Enter query genome file name: ");
9     scanf("%49s", query);
10    return 0;
11 }

```

Listing 2: Safe code generated by LLM

- **System:** You are a coding editor and help the user.
- **User:** I will give you a code that has vulnerabilities inside. Then, I will give you the output of different Static Application Security Testing tools. Based on the output, I want you to fix the code and only give back the whole code without anything else.
- **Assistant:** Certainly, I can help you analyze the C code and the SAST tools output to identify and fix any issues. Please provide the C code and the SAST tools output, and I'll do my best to assist you. I will give back the whole code fixed.
- **User:** Vulnerable code
- **Assistant:** I see the C code you've provided. To assist you further, please provide the output of the SAST tools and specify what issues or errors you're encountering. This will help me understand the problem and provide a more accurate fix for the code.
- **User:** Error type: CWE-119 identified at lines 7 and 9. Error message: scanf() without field width limits can crash with huge input data.

Figure 1: Conversational Prompt (Vulnerable Code is a placeholder for the code in Listing 1)

programming. CODEXITY will take the existing code snippet to initiate a prompt and generate an initial completion with the selected LLM. The completed code will be routed to a vulnerability detection phase by a series of static analysis tools. CODEXITY is integrated with two state-of-the-art static analyzers CppCheck [18] and Infer [6]. We selected these two tools to examine a wide range of vulnerabilities. Like Arusoae et al. [5], we also found CppCheck to be a generally good candidate. We added Infer because of its great ability to find memory-related bugs. If static analysis tools report any vulnerability, CODEXITY extracts the error/warning message and location information, along with the vulnerable program, to formulate a vulnerability-exposing prompt (see Figure 1). Finally, CODEXITY sends the vulnerability-exposing prompt to the LLM in the background and requests a vulnerable-free program.

3.2 Strategy 1: Iteration Repair

We now describe the default vulnerability-preventing strategy in CODEXITY. The *Iteration Repair* strategy employs commercial LLMs to generate vulnerable-free programs and provides an interface that allows users to specify the exact background LLM engine. The goal is to leverage the most powerful LLM that the user can access

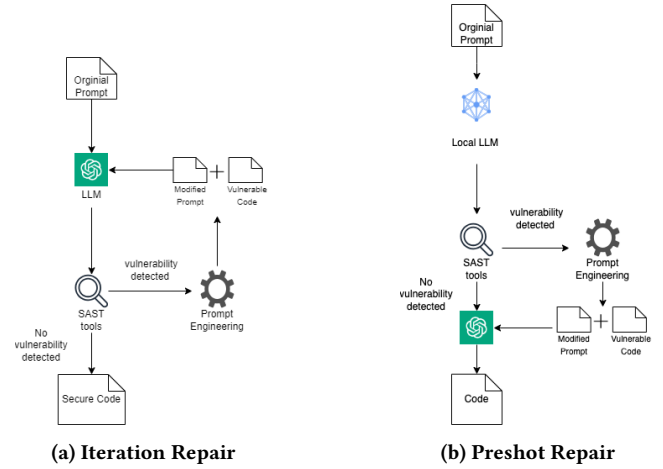


Figure 2: Codexity's Repair Strategies

to provide the most secure code generation service. Moreover, the API-accessible LLMs do not require users to be locally equipped with a high-end GPU for model inference. After generating a code, if a vulnerability is detected, the vulnerable code is sent back to the commercial LLM using its API. We repeat this until it generates one program for which the static analyzers report no vulnerability.

3.3 Strategy 2: Preshot Repair

Iteration repair aims to generate the best result by iteratively querying the model until a secure answer is found or the maximum allowed queries are reached. Although commercial LLMs provide better results, they might introduce high costs to the users. To balance the trade-off between cost and quality, we present an alternative vulnerability-preventing strategy called *Preshot Repair* shown in Figure 2b. We hypothesize that a weaker local (and hence cheaper) LLM is more prone to generate vulnerabilities. Such vulnerability information can be included in the query to the more costly and powerful LLM. Consequently, we aim to anticipate and prevent the flaws likely to surface in our target LLM's output, thus the term *Preshot Repair*. So, we first query a local LLM to generate an initial (vulnerable) code. We employ static analyzers to detect any vulnerability and, subsequently, use the analysis report in the prompt generation for the target LLM.

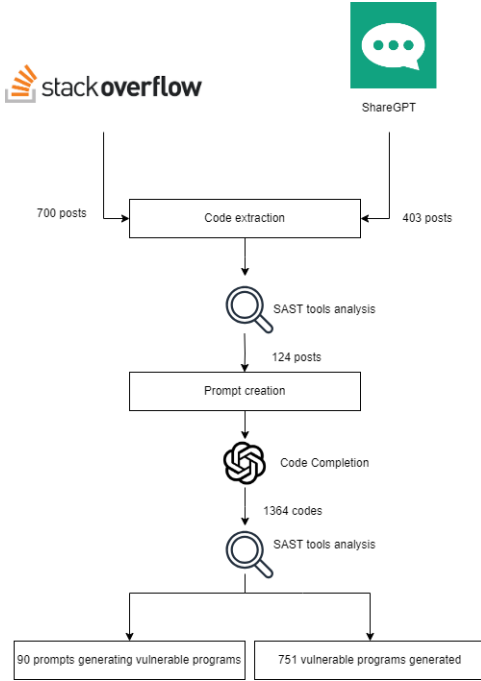


Figure 3: Dataset Construction

4 EVALUATION

We show CODEXITY’s effectiveness to securely handle developers’ code completion requests based on two real-world datasets and compare CODEXITY’s performance with FootPatch [25] and GitHub Copilot [1]. In particular, we explore three research questions:

- RQ1:** How effective is CODEXITY in preventing the generation of vulnerable programs?
RQ2: How does CODEXITY perform compared to FootPatch and GitHub Copilot?
RQ3: What are the benefits/drawbacks of the proposed workflows?

4.1 Evaluation Setup

Benchmark Construction. To simulate real-world scenarios of how AI-assisted programming may help software developers, we curated a benchmark of developer prompts that are prone to generate vulnerable programs from ShareGPT [2] and StackOverflow [3]. ShareGPT is a platform where LLM users can post their experience in formulating prompts and interactions with LLMs, whereas StackOverflow is a popular programming-oriented Question-Answering platform. Figure 3 shows the benchmark construction process. We first collected 403 user posts relevant to C programming queries by filtering all the posts in the ShareGPT dataset and the first 700 posts in StackOverflow using ‘c’ and ‘int main’ as keywords. Each user post consists of a question and an LLM response. We then employ a two-round vulnerable prompts detection strategy. In the first round, we extracted the code snippet from the LLM response and ran the static analyzers in CODEXITY on the extracted code snippet of the 403 programming posts. As a result, we identified 124 posts containing vulnerabilities in their response.

In the second round, we extracted the non-vulnerable part of the code snippet from the 124 posts and asked ChatGPT to complete the programming questions (using two temperature configurations) to confirm further whether they are prone to generate vulnerable programs. First, ChatGPT generates one completion of each prompt for the temperature at 0. Then, we executed ChatGPT again to generate ten completions of each prompt for temperature at 0.8. Finally, we reran the static analyzers on the $124 \times 11 = 1,364$ LLM-generated code completions. We specified a prompt as *vulnerable* if (1) ChatGPT produces a vulnerable program when the temperature is set to 0, or (2) ChatGPT produces at least one vulnerable program in one of the ten runs when the temperature is set to 0.8. Finally, we ended up with 90 vulnerable prompts and generated 751 vulnerable code completions with 1645 vulnerabilities.

Table 1 shows the details of our benchmark, categorized by vulnerabilities identified by CppCheck and Infer. We employed CppCheck for common CWEs and Infer for specific types like Memory leaks. Note that subjects could have multiple vulnerabilities. We defaulted to CWE classification when vulnerabilities overlapped.

Table 1: Vulnerabilities Categories

Vulnerability	Total	Vulnerability	Total
Null Dereference	384	CWE-686	15
Nullptr Dereference	363	Integer Overflow L2	13
Resource Leak	196	CWE-758	12
Buffer Overrun L2	119	CWE-197	12
Memory Leak	109	CWE-562	11
CWE-119	90	Buffer Overrun L1	11
CWE-457	81	CWE-467	10
CWE-401	66	Use After Lifetime	8
Buffer Overrun L3	62	CWE-685	7
CWE-775	32	CWE-476	4
CWE-788	22	Use After Free	2
Buffer Overrun S2	15	Inferbo Alloc Is Zero	1

Baseline Tools. We use FootPatch and GitHub Copilot as baseline tools in our comparison. We selected FootPatch because it also uses a SAST tool, Infer, to detect vulnerabilities. Also, we decided to compare with GitHub Copilot because it is one of the most famous code completion tools and runs with a similar GPT model.

Models. Throughout the experiment, we used the latest ChatGPT (gpt-3.5-turbo) as a commercial LLM code completion and fixing engine for CODEXITY. For the preshot repair, we used two different specialized code completion models: StarCoder [17] in GPTQ [9] format and SantaCoder [4] in GGML [12] format. These formats allow quantization, suitable for CPUs or less powerful GPUs. The models were run with a maximum prediction token of 1024 to be able to complete the whole code and with a temperature of 0.2 (following the same evaluation setup as the authors of StarCoder). For the GPTQ model, we used the publicly available model at the Hugging Face repository². Hugging Face is the equivalent of GitHub for sharing models. We obtained the GGML model by following the instructions in their GitHub repository.

²<https://huggingface.co/TheBloke/starcoder-GPTQ>

Table 2: Number of Vulnerable Codes generated

	# of vulnerable codes	% of vulnerable codes	Avg Time (s)	LoC
ChatGPT	751/990	75.9	39.2s	55.2
IR-ChatGPT	157/990	15.9	82.8s	60.6
PR-StarCoder-15.5B	389/990	39.3	45.4s	54.9
PR-SantaCoder-1.1B	459/990	46.4	72.4s	44.4

Technical Setup. Our experiments were conducted on a MacBook Pro 2019 (Intel Core i9 with 16GB RAM) for iteration repair and preshot repair with the GGML model. For the GPTQ model in the preshot strategy, we used a Ubuntu 18.04 Server with RTX 4090.

4.2 Experiment Result

RQ1: Vulnerability Prevention. We evaluated our tool on our 90 prompts that led to a vulnerable code generation and measured the number of vulnerable codes generated. We initially set a temperature of 0 for repairs in the iteration repair, as a high temperature can lead to a random output as mentioned in OpenAI documentation³. A code is determined vulnerable when the SAST tools detect a vulnerability. We also set the maximum number of iterations to 3 for the iteration repair. Table 2 shows the results of using CODEXITY in completing the *vulnerable* prompts of our benchmark. As mentioned in Section ??, the *baseline tool ChatGPT* generated for the 990 code completion attempts in our dataset 751 vulnerable programs (751/990=75.9%) with 1645 detected vulnerabilities. In the iteration repair setting, CODEXITY only generated 157 (157/990=15.9%) vulnerable programs with 338 detected vulnerabilities. Therefore, it achieves a reduction of 60% vulnerable programs. The results in Table 2 also show that preshot repair decreases the production of vulnerable codes by 36.6% when using StarCoder and 29.5% for SantaCoder. In some cases (6.1% for StarCoder and 8.5% for SantaCoder), the tool did not output a code but a comment, e.g., asking a question about the prompt. In this case, because it is impossible to say if the code is secure, we considered the output vulnerable.

RQ2: Comparison with FootPatch and GitHub Copilot. We compare CODEXITY with FootPatch on the 751 vulnerable subjects detected by Infer. FootPatch’s Infer found 20 vulnerabilities, including 19 null dereferences and one memory leak but patched none. The analysis of the log data revealed that FootPatch failed to address Null Dereferences when capturing the variable name:

```

1 Found error: NULL_DEREFERENCE
2 [+] Patchable error: [vulnerable_code.c]:[96] :[
    pointer newNode last assigned on line 95 could be
    null and is dereferenced at line 96, column 9]
3 [+] Patch generation routine started for bug "
    NULL_DEREF".
4 [+] Looking for pvar last in pname addSpecific
5 [=] I found these typs for pvar last
6 [-] No type for pvar found

```

Instead of extracting the pointer "newNode", FootPatch extracted "last", leading to an incorrect variable identification and a subsequent failure in the patch development. Similarly, Infer identified a vulnerability for the category Memory Leak but omitted the variable’s name, complicating the patch process. This behavior of

FootPatch is described in [25] as where the tool failed to resolve the program variable. We also compared CODEXITY with GitHub Copilot using its chat functionality. We asked Copilot to "write the next lines of the code" on our 90 prompts and took the first answer. Infer and CppCheck found 76 (84.44%) programs to be vulnerable.

RQ3: Tradeoffs. The iteration repair avoids generating vulnerabilities with a high success rate but requires multiple commercial LLM calls, increasing costs and generation time. On average, there are 1.8 repair iterations when a vulnerability is detected, and a generation takes 98.6 seconds (see Table 2). This can be explained by the introduction of new vulnerabilities after the iteration by the LLM, leading to additional iterations. On the other hand, preshot repair utilizes a local LLM, minimizing API calls and time. For the GPTQ model, the repair adds about 6 seconds. For the GGML model, the generation time is slower because the model is run on a CPU. Moreover, the vulnerable code generation rate is higher than the iteration repair for all the models because we do not give a second chance to the preshot repair in case a vulnerability is detected after the commercial LLM generation. The iterative repair strategy is optimal for users prioritizing secure code generation, albeit with a longer generation time. Conversely, the preshot repair strategy benefits those needing swift code generation but with a heightened level of security. For instance, preshot repair using ChatGPT coupled with StarCoder offers an average generation time similar to ChatGPT yet provides improved security.

5 RELATED WORK

He et al. [13] introduced an innovative learning strategy for improved secure code generation. Other research includes works by Olausson et al. [21], Pearce et al. [23], and Charalambous et al. [7], each exploring LLMs efficacy in fixing code vulnerabilities. However, these studies often adopt vulnerability detection techniques that are not suitable for IDE-integrated code completion tasks. Pearce et al. [23] used CodeQL, a vulnerability detection tool that scales to large codebases but is inefficient for analyzing short, single code snippets. Charalambous et al. [7] implemented the Bounded Model Checking method, limiting the vulnerability spectrum. Conversely, Olausson et al. [21] chose to engage the model for analyzing the error message; adding an extra call to a model can increase the required detection time. Chen et al. [8] discussed using multiple LLMs to boost result quality. In contrast to these existing works, we integrate LLMs and SAST tools, specifically for tackling vulnerabilities, while considering the efficiency and practicality of the code completion tasks in the IDE.

³<https://platform.openai.com/docs/api-reference/chat/create>

6 CONCLUSION

We introduced CODEXITY that addresses vulnerabilities in LLM-generated code. It deploys two distinct repair strategies: iteration repair and preshot repair. Our evaluation shows that they can reduce the generation of vulnerable code by 60%. In future, it will be essential to improve the code generation efficiency, e.g., by combining CODEXITY and LLM fine-tuning to reduce the need for repair iterations. Furthermore, it will be interesting to explore CODEXITY for other popular programming languages, such as Java or Python.

ACKNOWLEDGMENTS

This work was partially supported by a Singapore Ministry of Education (MoE) Tier 3 grant "Automated Program Repair", MOET32021-0001.

REFERENCES

- [1] [n. d.]. *GitHub Copilot*. <https://github.com/features/copilot>, last accessed on 01/01/24.
- [2] [n. d.]. *ShareGPT*. <https://sharegpt.com/>, last accessed on 01/01/24.
- [3] [n. d.]. *Stack overflow*. <https://stackoverflow.com/>, last accessed on 01/01/24.
- [4] Loubna Ben Allal, Raymond Li, Denis Kocetkov, Chenghao Mou, Christopher Akiki, Carlos Munoz Ferrandis, Niklas Muennighoff, Mayank Mishra, Alex Gu, Manan Dey, et al. 2023. SantaCoder: don't reach for the stars! *arXiv preprint arXiv:2301.03988* (2023).
- [5] Andrei Arusoaie, Stefan Ciobăca, Vlad Craciun, Dragos Gavrilut, and Dorel Lucanu. 2017. A Comparison of Open-Source Static Analysis Tools for Vulnerability Detection in C/C++ Code. In *2017 19th International Symposium on Symbolic and Numeric Algorithms for Scientific Computing (SYNASC)*. 161–168. <https://doi.org/10.1109/SYNASC.2017.00035>
- [6] Cristiano Calcagno and Dino Distefano. 2011. Infer: An Automatic Program Verifier for Memory Safety of C Programs. In *NASA Formal Methods*, Mihaela Bobaru, Klaus Havelund, Gerard J. Holzmann, and Rajeev Joshi (Eds.). Springer Berlin Heidelberg, Berlin, Heidelberg, 459–465.
- [7] Yiannis Charalambous, Norbert Tihanyi, Ridhi Jain, Youcheng Sun, Mohamed Amine Ferrag, and Lucas C Cordeiro. 2023. A New Era in Software Security: Towards Self-Healing Software via Large Language Models and Formal Verification. *arXiv preprint arXiv:2305.14752* (2023).
- [8] Lingjiao Chen, Matei Zaharia, and James Zou. 2023. FrugalGPT: How to Use Large Language Models While Reducing Cost and Improving Performance. *arXiv preprint arXiv:2305.05176* (2023).
- [9] Elias Frantar, Saleh Ashkboos, Torsten Hoeftler, and Dan Alistarh. 2022. Gptq: Accurate post-training quantization for generative pre-trained transformers. *arXiv preprint arXiv:2210.17323* (2022).
- [10] Yujia Fu, Peng Liang, Amjed Tahir, Zengyang Li, Mojtaba Shahin, and Jiaxin Yu. 2023. Security Weaknesses of Copilot Generated Code in GitHub. *arXiv preprint arXiv:2310.02059* (2023).
- [11] Xiang Gao, Bo Wang, Gregory J Duck, Ruyi Ji, Yingfei Xiong, and Abhik Roychoudhury. 2021. Beyond tests: Program vulnerability repair via crash constraint extraction. *ACM Transactions on Software Engineering and Methodology (TOSEM)* 30, 2 (2021), 1–27.
- [12] Georgi Gerganov. [n. d.]. *GGML - AI at the edge*. <https://ggml.ai/>, last accessed on 23/10/23.
- [13] Jingxuan He and Martin Vechev. 2023. Large Language Models for Code: Security Hardening and Adversarial Testing. (2023). <https://arxiv.org/abs/2302.05319>
- [14] Zhen Huang, David Lie, Gang Tan, and Trent Jaeger. 2019. Using safety properties to generate vulnerability patches. In *2019 IEEE Symposium on Security and Privacy (SP)*. IEEE, 539–554.
- [15] Raphaël Khoury, Anderson R Avila, Jacob Brunelle, and Baba Mamadou Camara. 2023. How Secure is Code Generated by ChatGPT? *arXiv preprint arXiv:2304.09655* (2023).
- [16] Claire Le Goues, Michael Pradel, Abhik Roychoudhury, and Satish Chandra. 2021. Automatic Program Repair. *IEEE Software* 38, 4 (2021), 22–27. <https://doi.org/10.1109/MS.2021.3072577>
- [17] Raymond Li, Loubna Ben Allal, Yangtian Zi, Niklas Muennighoff, Denis Kocetkov, Chenghao Mou, Marc Marone, Christopher Akiki, Jia Li, Jenny Chim, et al. 2023. StarCoder: may the source be with you! *arXiv preprint arXiv:2305.06161* (2023).
- [18] Daniel Marjamaki. [n. d.]. *Cppcheck: A Tool for Static C/C++ Code Analysis*. <https://sourceforge.net/projects/cppcheck/>, last accessed on 18/10/23.
- [19] Hoang Duong Thien Nguyen, Dawei Qi, Abhik Roychoudhury, and Satish Chandra. 2013. Semfix: Program repair via semantic analysis. In *2013 35th International Conference on Software Engineering (ICSE)*. IEEE, 772–781.
- [20] Yannic Noller, Ridwan Shariffdeen, Xiang Gao, and Abhik Roychoudhury. 2022. Trust Enhancement Issues in Program Repair. In *Proceedings of the 44th International Conference on Software Engineering (Pittsburgh, Pennsylvania) (ICSE '22)*. Association for Computing Machinery, New York, NY, USA, 2228–2240. <https://doi.org/10.1145/3510003.3510040>
- [21] Theo X Olausson, Jeevana Priya Inala, Chenglong Wang, Jianfeng Gao, and Armando Solar-Lezama. 2023. Demystifying GPT Self-Repair for Code Generation. *arXiv preprint arXiv:2306.09896* (2023).
- [22] Hammond Pearce, Baleegh Ahmad, Benjamin Tan, Brendan Dolan-Gavitt, and Ramesh Karri. 2022. Asleep at the Keyboard? Assessing the Security of GitHub Copilot's Code Contributions. In *2022 IEEE Symposium on Security and Privacy (SP)*. 754–768. <https://doi.org/10.1109/SP46214.2022.9833571>
- [23] Hammond Pearce, Benjamin Tan, Baleegh Ahmad, Ramesh Karri, and Brendan Dolan-Gavitt. 2023. Examining Zero-Shot Vulnerability Repair with Large Language Models. In *2023 IEEE Symposium on Security and Privacy (SP)*. 2339–2356. <https://doi.org/10.1109/SP46215.2023.10179324>
- [24] Ridwan Shariffdeen, Yannic Noller, Lars Grunske, and Abhik Roychoudhury. 2021. Concolic program repair. In *Proceedings of the 42nd ACM SIGPLAN International Conference on Programming Language Design and Implementation*. 390–405.
- [25] Rijnard van Tonder and Claire Le Goues. 2018. Static Automated Program Repair for Heap Properties. In *Proceedings of the 40th International Conference on Software Engineering (Gothenburg, Sweden) (ICSE '18)*. Association for Computing Machinery, New York, NY, USA, 151–162. <https://doi.org/10.1145/3180155.3180250>
- [26] Yuntong Zhang, Xiang Gao, Gregory J Duck, and Abhik Roychoudhury. 2022. Program vulnerability repair via inductive inference. In *Proceedings of the 31st ACM SIGSOFT International Symposium on Software Testing and Analysis*. 691–702.

```

1 #include <stdio.h>
2
3 int main(){
4     char c, w[50];
5
6     printf("Enter a character: ");

```

(a) User Prompt

```

1 #include <stdio.h>
2
3 int main(){
4     char c, w[50];
5
6     printf("Enter a character: ");
7     scanf("%c", &c);
8     printf("Enter a word: ");
9     scanf("%s", w);
10
11     printf("Character: %c\n", c);
12     printf("Word: %s\n", w);
13
14     return 0;
15 }

```

(b) Code generated by GitHub Copilot

```

1 #include <stdio.h>
2
3 int main(){
4     char c, w[50];
5     printf("Enter a character: ");
6     scanf("%c", &c);
7     printf("Enter a word: ");
8     scanf("%49s", w); // Added field width limit of 49 to prevent buffer overflow
9     printf("Character: %c\n", c);
10    printf("Word: %s\n", w);
11    return 0;
12 }

```

(c) Code generated by CODEXITY with Iteration Repair

```

1 #include <stdio.h>
2
3 int main(){
4     char c, w[50];
5
6     printf("Enter a character: ");
7     scanf("%c", &c);
8
9     printf("Enter a word: ");
10    scanf("%49s", w); // Limit input to 49 characters to avoid buffer overflow
11
12    printf("You entered: %c and %s\n", c, w);
13
14    return 0;
15 }

```

(d) Code generated by CODEXITY with Preshot Repair

Figure 4: Demo Screenshots

A DEMO WALKTHROUGH

The demonstration of our tool is showcased in our video⁴, where we discuss the motivation, various strategies, and the practical use of CODEXITY. CODEXITY’s demonstration involves the code completion for the snippet depicted in Figure 4a. We incorporated our tool into a Visual Studio Code extension for practical usage. In our demonstration, we showcase three ways of automated code completion in Visual Studio Code:

- (1) utilizing GitHub Copilot,
- (2) utilizing CODEXITY with the Iteration Repair strategy, and
- (3) utilizing CODEXITY with the Preshot Repair strategy.

⁴<https://www.youtube.com/watch?v=om6CYGfbNnM>

Launching CODEXITY is similar to GitHub Copilot. The user needs to highlight the prompt that should be completed (e.g., a code comment or some partial code snippet) and then launch the extension, which will trigger our guided code completion using ChatGPT in the background. We conclude the demonstration by comparing the outcomes of the three generated code variants. The code generated by GitHub Copilot exhibited a potential buffer overflow issue, as illustrated in Figure 4b at line 9, due to the possibility of exceeding the maximum size of the variable ‘w’ based on the input. However, the iteration and preshot repair methods produce code that does not contain vulnerabilities (see Figures 4c and 4d).